

DSCI 519 Project

Aaron Savio Lobo

alobo@usc.edu

9160382742

Using Document what is considered PHI:

Any health information that can be used to identify the patient is considered PHI and should be kept secure. Any of the following identifiers in the information needs to be stripped off for HIPAA rules not to apply to it. These include:

- Names (Full OR Last and initial)
- Geographical Identifiers (Smaller than a state, excluding the initial three digits of a zip code)
- Dates related to an individual (Excluding the year)
- Phone Numbers
- Fax numbers
- Email addresses
- Social Security numbers
- Medical record numbers
- Health insurance beneficiary numbers
- Account numbers
- License numbers
- Vehicle identifiers (including serial numbers and license plate numbers)
- Device identifiers and serial numbers
- Web Uniform Resource Locators
- Internet Protocol (IP) address
- Biometric identifiers, including finger, retinal, and voice prints
- Full-face photographic images and any comparable images
- Any other unique identifying number, characteristic, or code except the unique code assigned by the investigator to code the data

If the data contains any of these fields, it is considered PHI and all the HIPAA rules apply to it.

Assumptions:

The Center which is part of a hospital uses Cartagena's product to perform data analysis. The Center uses AWS to store data. There are BAAs between them. Since Cartagena signed a BAA with HC, they need to follow my recommendations too.

Using the NIST Document:

Since the Center is part of HC, they deal with PHI and have to implement HIPAA Security rules. These rules are focused on protecting ePHI which is PHI in electric format. Their goal is to maintain the Confidentiality, Integrity, and availability of ePHI. According to the NIST Document, the following policies should be implemented by the Center:

- Administrative Safeguards:
 - Security Management Process: Policies to prevent, detect, contain, and rectify security violations. Includes risk assessments and management.
 - Assigned Security Responsibility: Select a security official who will be responsible for HIPAA policies.
 - Workforce Security: Policies to ensure employees have appropriate access to ePHI. Determine proper clearances of employees for access.
 - Information Access Management: Policies for authorizing access to ePHI.
 - Security Awareness and Training: Conduct training to increase awareness among employees on the HIPAA policy and its violations.
 - Security Incident Procedures: Policies and procedures to deal with any security incidents.
 - Contingency plan: Establish procedures to deal with events that can cause damage to the systems having ePHI.
 - Evaluation: Conduct periodic evaluations to check how any changes affect the security of ePHI.

- Business Associate Contracts: The covered entity (The center) permits business associates to deal with ePHI on its behalf as long as it trusts the BA to enforce HIPAA policies.
- Physical Safeguards:
 - Facility Access Controls: Policies to ensure that proper access to the facilities is enforced where the ePHI is stored.
 - Workstation Use: Policies that specify how the workstations should be used that access ePHI
 - Workstation Security: Policies for physical control of these workstations
 - Device and Media Controls: Policies for restricting the removal of hardware that contains ePHI outside or within the facility.
- Technical Safeguards:
 - Access Control: Grant access to only those users as defined in "Information Access Management" to ePHI
 - Audit Controls: Have mechanisms in place that record and examine activity in systems that have ePHI.
 - Integrity: Policies and procedures to prevent ePHI from corruption or unauthorized modifications.
 - Entity Authentication: Verify the identity of the user trying to access ePHI.
 - Transmission Security: Protecting ePHI data that is being transmitted over electronic communications means.

Using the HC Document:

HC Policies mentioned and additional recommendations:

- Administrative Safeguards:
 - Risk Assessment of the company should be done to find out vulnerabilities that affect the CIA of the protected data and management of this risk should be done. The Bioinformatics director should appoint a chief risk officer for this.
 - The Bioinformatics Director is responsible for maintaining HIPAA compliance while processing, analyzing, transferring, and storing all data generated, The Laboratory Supervisor is responsible for maintaining HIPAA compliance within the center.
 - Employees should be background checked and assigned a clearance based on how much they can be trusted with ePHI data.
 - Every employee working on ePHI should be made to sign an NDA when they are hired.
 - Minimum access to protected data should be given to employees, only enough to do their job.
 - All Employees who deal with clinical data should undergo training on not violating the HIPAA policy.
 - An incident response team should be set up to deal with security incidents as early as possible.
 - Take backups of data incrementally Mon-Fri at night and Saturday afternoon to ensure availability of ePHI in case of system failures or damages.
 - Backups are stored on AWS servers, in case of damage to any of the servers that have ePHI information, the backup is used to restore the data.
 - The administration and recovery of the data is done using Tivoli Storage Manager (TSM).
 - The Bioinformatics director should perform regular evaluations to check if the policies set in place make the system HIPAA compliant.
 - The Center should have a Business Associate Agreement with its vendors Cartagenia and AWS since they deal with data containing ePHI on the center's behalf so that they maintain the HIPAA compliance standards.
- Physical Safeguards:
 - A lock controls access to the HC server room. Only the Bioinformatic Director, IT employees in charge, and approved vendors are given the key. Everyone's entry to the server room is logged with the in time, reason for visit, and out time.
 - Any hardware change or maintenance done by vendors should also be logged.

- Only a limited number of workstations should be allowed to connect to the servers that have ePHI stored.
- The workstations that are allowed to access protected data should be on-premises or use a VPN service if working remotely.
- No protected data can be transferred onto external hardware like flash drives, etc.
- Technical Safeguards:
 - Access Control Policies:
The Center implements MAC MLS policy and DAC policy for access control. These policies determine which users can access what. Further elaborate in the section ahead.
 - All access to the hospital network and servers that have ePHI data, and any changes made to them should be logged. The logged data can be used for auditing purposes in the future.
 - Data that is stored should have their hash value calculated to check for the integrity of the protected data, CRC mechanisms should be used to check for corruption in data.
 - Hash values and CRC should be checked for data that is stored at regular intervals.
 - When accessing non-hospital integrated equipment, a username and password should be provided to verify the identity of the employee. This username and password should be given by the Bioinformatics director to the employee.
 - When accessing hospital-integrated equipment, a username and password should be provided by the employee that is given by the IT team.
 - Every workstation should need authentication, and any access to protected data servers should require authentication again with MFA.
 - Transmission security every time data is transferred, the hash value should be checked.
 - All protected data being transferred should be encrypted via secure protocols.
 - Transfers of protected data outside the hospital network are prohibited unless requested by a patient or doctor.
 - Clinical Data being transferred outside the hospital should be stripped off the HCUID and replaced with a UUID. (Raw NGS data does not have any identifiers, hence HCUID does not need to be removed for that)
 - Data being transferred for research should have HCUID replaced with PLMUID.
 - Data being produced on vendor equipment should be transferred locally temporarily and copied into the primary archive.
 - Based on the data and its use, the retention period of the data is decided. The period can be Temporary, short-term, intermediate, long-term, or indefinite.
 - Data recovery may be performed from the primary archive by the Bioinformatics Director in case of any loss of data on local storage.
 - Communications within the center need to be done via work emails only.
 - Every access and action should be logged, and these logs should be audited regularly.

Using the Cartagena Document:

Cartagenia Policies mentioned and additional recommendations:

- PHI information entered into the Bench platform is controlled by the center.
- Cartagenia does not get any ownership of the data entered into its platform, original ownership is maintained.
- All employees and vendors working with Cartagenia have to sign NDA to ensure the confidentiality of the protected data they work with.
- No Cartagenia employee may access HC data that is being sent to their platform without the permission of HC.
- Any protected information that a Cartagenia employee works with on permission of HC (maybe because of support purposes) may be deleted after its intended use.
- The data entered by Cartagenia's customers (HC) into the Bench platform has to be replicated across multiple devices and multiple data centers to ensure availability.

- Snapshots of database servers should be taken every day and maintained for at least 30 days.
- Any transfers in and out of Cartagena are encrypted using industry-grade 256-bit encryption.
- Customer data (HC) transfer via mobile storage devices is permitted only within the premises and this data should be deleted after the transfer is successful.
- All computers of Cartagena employees that work with customer data (HC) should be password protected and should be logged off after 5 minutes of inactivity.
- For access to the Bench platform, a user needs to be authenticated first.
- The Bench platform only allows one user session from an authenticated account and the older session should automatically be logged out.
- An authenticated session lasts only up to 30 minutes of inactivity after which the user needs to log in again.
- Password policy for bench: For initial access, a temporary password is provided which is valid for 12 hours and needs to be changed after that. The changed password needs to be longer than 8 characters and have a numerical character, special character, and uppercase character atleast. After three failed login attempts, the account is disabled and the customer will need to contact the Cartagena help desk.
- User types are assigned to each user accessing Bench (Described in Access control policy part) that have read, write or administrator privileges. Access to projects is specified too.
- Every operation performed by a user on the Bench platform is logged.

Threats:

- Employees might fall prey to social engineering attacks like phishing attacks and give away their credentials which gives the attacker access to ePHI.
- Lack of proper background checks can lead to untrustworthy individuals being hired and open up room for potential insider attacks.
- Employees setting weak passwords can result in an attacker brute-forcing the credentials of the user to get access to the protected data.
- Employees might download files containing Trojan Horses from malicious websites which ends up having ransomware and encrypts the protected data.
- A server can get stolen from the data center or damaged leading to loss of the protected data.
- The equipment used to collect data can have backdoors in it which lets an attacker steal protected data.
- The Bench might have a backdoor in its code that an attacker could find and use to send the protected data to them rather than to the servers where they are to be stored.
- Improper access control measures and not practicing least privilege can lead to unauthorized individuals accessing and modifying data.
- The business associate agreements with third-party companies could be weak and not properly protect ePHI.
- The login pages might be prone to injection attacks that let the attacker input commands to return protected data present the databases.
- An attacker may target the center by overwhelming their servers leading to a DOS attack.
- Cartagena employees may access the HC's protected data without any permissions.
- HLA lab employees may access overall clinical and research data and not just the data from the lab.
- Users who have access to research data with human subjects might access it without IRB approval.
- Both Cartagena and HC use MD5 as their hashing algorithm which has been proven to have collisions. An attacker could find a collision and modify the data without the hash value of the file being changed.
- The log files in HC can be modified by an attacker to erase their tracks.

Access Control:

HC:

Users: IT Director, Bioinformatics Director, Bioinformatics Supervisor, System Administrator, Employees, Contractors.

Groups:

- Root: Users in this role can read and write all kinds of data.
- Bioinfo: Users in this role can read and write non-clinical data.
- Bioinfoclin: Users in this role can read and write clinical data.
- Clinical: Users in this role can read and write clinical data.
- Research: Users in this role can read and write research data. Need IRB approval for research data on humans.
- HLA: Users in this role can read and write research data or clinical data only from the HLA lab. Need IRB approval for research data on humans.
- Smbusers: Users in this role can read and write instrument configuration files.

Objects:

- Clinical: Clinical data including clinical software. This includes data in the HLA lab.
- Non-Clinical: Non-clinical data including non-clinical software.
- Research: Research data including research software. This includes data in the HLA lab.
- HResearch: Research data on humans.
- ClinicalHLA: Clinical data and software from the HLA lab.
- ResearchHLA: Research data and software from the HLA lab.
- HResearchHLA: Research data on Humans from the HLA lab.
- IConfig: Instrument Configuration files
- Admin: Administrative data, who has access to what including the Bench platform.

Based on what access is required, Users are assigned to groups. The following user-to-group assignment is as follows.

- Root: IT Director, Bioinformatics Director, Bioinformatics Supervisor, System Administrator.
- All other groups have employees and contractors (who sign NDA) in them.

Mandatory Access Policy (MAC):

The center should adopt a Multi-level Security MAC policy. The access control policy of the HC follows BLP rules (No read up and no write down). The subjects in this policy are the user groups.

Clearances that can be assigned to subjects are:

- Top Secret
- Secret
- Confidential

Objects can be classified into:

- Top Secret
- Secret
- Confidential

Categories based on need-to-know are:

- HLA: Anything that is related to HLA lab.
- Ad: For administrative purposes. This includes admin rights for the Bench platform.
- IRB: Employees that have IRB approval.
- Config: To configure the instruments.

Access Classes of the Subjects:

Subject	Access Class
Root	Top Secret {HLA, IRB, AD, Config}
Bioinfo	Secret {}
Bioinfoclin	Top Secret {}
Clinical	Top Secret {}
Research	Confidential {IRB}
HLA	Top Secret {HLA, IRB}
Smbusers	Confidential {Config}

Access Classes of the Objects:

Object	Access Class
Clinical	TopSecret {}
Non-Clinical	Secret {}
Research	Confidential {}
HResearch	Confidential {IRB}
ClinicalHLA	Top Secret {HLA}
ResearchHLA	Confidential {HLA}
HResearchHLA	Confidential {HLA, IRB}
IConfig	Confidential {Config}
Admin	Top Secret {AD}

Dom Relationships:

Access Class mapping to number:

1. Top Secret {HLA, IRB, AD, Config}
 2. Top Secret {HLA, IRB}
 3. Top Secret {HLA}
 4. Top Secret {AD}
 5. Top Secret {}
 6. Secret {}
 7. Confidential {HLA, IRB}
 8. Confidential {Config}
 9. Confidential {IRB}
 10. Confidential {HLA}
 11. Confidential {}
- 1 dom 1, 1 dom 2, 1 dom 3, 1 dom 4, 1 dom 5, 1 dom 6, 1 dom 7, 1 dom 8, 1 dom 9, 1 dom 10, 1 dom 11
 - 2 dom 2, 2 dom 3, 2 dom 5, 2 dom 6, 2 dom 7, 2 dom 9, 2 dom 10, 2 dom 11
 - 3 dom 3, 3 dom 5, 3 dom 6, 3 dom 10, 3 dom 11
 - 4 dom 4, 4 dom 5, 4 dom 6, 4 dom 11
 - 5 dom 5, 5 dom 6, 5 dom 11
 - 6 dom 6, 6 dom 11
 - 7 dom 7, 7 dom 9, 7 dom 10, 7 dom 11
 - 8 dom 8, 8 dom 11
 - 9 dom 9, 9 dom 11
 - 10 dom 10, 10 dom 11
 - 11 dom 11

Applying Simple Security Property and *-Property of BLP, we have the following:

- Users in Root can Read and Write everything.
- Users in Bioinfo can read Non-Clinical, Research and can write Non-Clinical and Clinical
- Users in Bioinfoclin can read clinical and non-clinical, Research, and write Clinical.
- Users in Clinical can read clinical and non-clinical, Research and write Clinical.
- Users in Research can read research and HResearch and write clinical, non-clinical, research, and HResearch.
- Users in HLA can read Clinical, Non-Clinical, Research, HResearch, Clinical HLA, ResearchHLA, HResearchHLA and write Clinical and ClinicalHLA
- Users in Smbusers can read research, IConfig, and write Research, IConfig, Non-Clinical, and Clinical.

Discretionary Access Control Policy (DAC):

The above-mentioned accesses resulted from the implementation MAC policy with the BLP model. To reach our required access policy as mentioned under the “Groups” heading, a DAC policy needs to be applied on top of this MAC policy. For any access, the MAC policy is checked first, if permitted by the MAC policy, the DAC ACL is checked next.

The following is the ACL:

R/W – Read and Write Access

Blank Cells – No access

Object\Subject	Root	Bioinfo	Bioinfoclin	Clinical	Research	HLA	Smbusers
Clinical	R/W		R/W	R/W			
Non-Clinical	R/W	R/W					
Research	R/W				R/W		
HResearch	R/W				R/W		
ClinicalHLA	R/W					R/W	
ResearchHLA	R/W					R/W	
HResearchHLA	R/W					R/W	
IConfig	R/W						R/W
Admin	R/W						

Hence, the required access policies can be applied using a combination of MAC and DAC policies.

Cartagenia:

- Within the company, Cartagenia has only one type of user who interacts with HC and that is the help desk personnel. HC has a BAA with Cartagenia, so they have to maintain HIPAA compliance while handling HC’s data.
- These helpdesk personnel are the “Contractors” who works with HC who signs the NDA. When any of the HC users face an issue with the Bench Platform, they contact these personnel to help them. This person may be given access to some protected information which he has to delete after solving the HC employee’s issue.
- Within the product (Bench), Cartagenia gives the HC an option to choose the type of user (Read only, Read-Write user) and admin. The admin user is appointed by the “Contractor” in the HC. The admin user has complete access to the platform. Giving more users admin rights can only be done by the “Contractor” who is a Cartagenia employee that works on a contract basis in HC.

AWS:

- The center and cartagenia use AWS services to store their data and for data recovery in case of any loss of data locally. The center has a BAA with AWS to maintain HIPAA compliance of the protected data that they store in the AWS servers.
- Access to this backup data is controlled by AWS Identity and Access Management (IAM) that gives the center functionality to restrict access using RBAC.

Requirements not covered by access control policies:

Availability (Using the AWS documents):

- Access control policies account for the confidentiality and integrity of data. Availability of protected information is still an essential aspect. Since the center and Cartagena use AWS services to store backups of the protected data, AWS provides functionality to maintain the data availability that they use.
- Loss or deletion of data from the local storage will affect the availability of that data that needs to be used again. Any data should be backed up on the AWS servers (EC2, S3, and Glacier). The data can then be recovered from these servers when needed. This recovery can only be initiated by the Bioinformatics Director or Supervisor.
- The TSM is used for the administration and management of backups too.
- AWS servers that store this protected data for the center have a Business Associate Agreement (BAA) with the center that ensures they maintain HIPAA compliance. AWS has Amazon Cloudwatch that allows monitoring of the servers. Threshold values on the server resources can be set so that when crossed an alert is generated. This can be used to detect unusual activity and potentially a DOS attack.
- Cartagena's bench platform's database is hosted on AWS S3. Any data that the center inputs into the bench platform is replicated across multiple data centers.

Authentication

- For the access control policies to apply, a user needs to be authenticated first.
- First, every employee needs to log in to their workstation. Every workstation needs to be password protected.
- The designated workstations that are on-premise and have access to protected data need to have multi-factor authentication.
- The employees who access protected data remotely need to be authenticated to the VPN that connects them to the network having the protected data.
- All workstations should automatically lock after 5 minutes of inactivity.
- To access the bench platform too, another layer of authentication is required. This authentication has the password and authentication policies given by Cartagena in section 1.
- As mentioned in Section 1, the authenticated bench session will last only for 30 minutes of inactivity.

Encryption

- Data that is stored locally and even on the backup servers should be encrypted to protect its confidentiality.
- Strong encryption algorithms should be used.
- Data being transferred between the three entities should be transferred only using secure protocols that provide strong encryption like SFTP, SSH, Amazon Snowball, etc.
- AWS Key Management Service (KMS) has Master Keys that can be used to encrypt and decrypt the encryption keys that are used by Cartagena and HC to encrypt ePHI.
- When data is being sent to patients or doctors, that too should be encrypted. The requesting entity should provide a password (key) that is used to decrypt the protected data.

Hashing

- All data and files have their hash values calculated using a hashing algorithm.

- To ensure that the data stored in the backup has not been tampered with or corrupted, the hash values are checked regularly.
- After every transfer, files should be checked for their hash value to ensure they haven't been tampered with during the transfer.

Background Checks

- Cartagena and the HC have to conduct detailed background checks on employees that deal with the protected information.
- This check includes contacting previous employers, criminal record check, etc.

Security Awareness

- Only employees who have been trained on HIPAA policies should be permitted to deal with protected data.
- Training should be conducted during the onboarding process and should be made compulsory before users get access to any privileged account. This applies to HC employees and Cartagena employees that work with the Center.

Threat space addressed by Access control policies:

- Having proper access control in place can protect against Trojan horses that an employee may download. Since the trojan horse will be working with the privileges of the user that downloaded it, it won't be able to modify any of the data that the user doesn't have the privilege to access. Hence, if the trojan horse is ransomware, the data it can encrypt will be restricted.
- Using the access control policies, every user is given the least number of privileges. That is, they're given only enough permissions required to do their job. Hence, even if they fall prey to a phishing attack and lose their credentials, the amount of data that an attacker can steal or corrupt will be limited.
- As mentioned by the access-controlled policies, the cartagenia employees are not allowed to access data from HC without permission. The contractor is permitted to help HC employees with the platform only when required.
- Adding categories to the MAC policy for HLA employees and DAC restrictions ensures that they are limited only to the data from the HLA lab.
- Adding the IRB category as a requirement to access data that needs IRB approval prevents any employees without IRB approval from accessing research data that had human subjects.

Threat space not addressed by Access control Policies and Recommendations to address them:

- The number of phishing attacks that reach employee email inboxes can be reduced by adding email filters. Marking every external email with "[EXTERNAL]" can make them more alert about clicking links or downloading attachments from people who are not employees of the HC. Conducting regular phishing simulations and then educating the users who fell for the simulation will also improve user awareness.
- Both Cartagena and HC should make it compulsory for employees to use passphrases instead of passwords. It makes them less prone to a brute force attack.
- The servers that have the protected data should be placed in isolated rooms with 24/7 security guards and CCTV cameras. Only highly trusted individuals should be allowed to enter this room like the IT Director and the Bioinformatics Director.
- Stronger hashing algorithms should be used instead of MD5 which has been proven to have collisions (SHA-256, SHA-512)
- Even if the users lose their credentials, having multi-factor authentication in place can reduce the probability of the attacker gaining access to the account. A password change should be required every three months to further restrict any compromised accounts.

- The Bench platform should be checked for satisfying the RM principles to ensure no backdoors are present.
- Every access in both Cartagena and HC has to be logged. This log file can only be accessed and managed by the security team of both companies. A SIEM should be used to filter logs and generate any alerts from suspicious activities.
- The HIPAA BAA should be reviewed properly before establishing business with any vendor.
- Firewalls should be used to drop unnecessary network traffic that is being sent to the HC servers. This can prevent a potential DOS attack.
- Proper testing should be conducted for fields that take user input to ensure that it is sanitised to avoid the possibility of an injection attack.

References:

1. What is Considered Protected Health Under HIPAA
2. HC-C04107 Data Policies
3. Cartagena Data Security and Confidentiality Policy
4. Architecting for HIPAA Security and Compliance on Amazon Web Services
5. AWS Disaster Recovery
6. AWS HIPAA Compliance White Paper
7. NIST_800_66r1